

EXAMEN FINAL PRATIQUE — SÉCURITÉ DES DONNÉES

Licence 3 — Cybersécurité

Durée : 7 à 10 jours

Type : Travail pratique individuel

Note : /20

Livrables : Rapport + dépôt Git + démonstration

1. CONTEXTE ET SCÉNARIO

Une organisation souhaite prochainement mettre en production une application web permettant à ses utilisateurs de créer un compte, de s'authentifier et d'accéder à différentes ressources contenant des données potentiellement sensibles.

Avant son déploiement, l'équipe de sécurité vous confie la mission suivante :

Réaliser une évaluation de sécurité de l'application, identifier les vulnérabilités susceptibles de compromettre la protection des données, analyser leurs impacts, proposer des mesures de remédiation et intégrer des contrôles de sécurité dans un pipeline automatisé.

Vous intervenez en tant que **Cybersecurity Analyst / Junior DevSecOps Engineer**.

Votre travail devra démontrer votre compréhension des concepts étudiés durant le semestre, notamment :

- vulnérabilités applicatives ;
- OWASP ;
- CWE ;
- injections SQL et autres injections ;
- authentification et contrôle d'accès ;
- protection des données ;
- confidentialité, intégrité et disponibilité ;
- analyse de risques ;
- outils d'analyse de sécurité ;
- SAST/DAST/SCA ;
- automatisation des contrôles ;
- Jenkins et CI/CD ;
- interprétation des résultats des outils.

2. OBJECTIFS DE L'EXAMEN

À l'issue de cet examen, l'étudiant devra être capable de :

1. **Identifier** des vulnérabilités de sécurité dans une application.
2. **Classifier** les vulnérabilités selon les CWE pertinentes.
3. **Analyser** leur impact sur la sécurité et la protection des données.
4. **Évaluer** la criticité et prioriser les risques.
5. **Proposer ou implémenter** des mesures de remédiation.
6. **Vérifier** l'efficacité des corrections.
7. **Automatiser** des contrôles de sécurité dans un pipeline CI/CD.
8. **Interpréter** les résultats produits par les outils.
9. **Formuler une décision argumentée concernant la mise en production.**

3. TRAVAIL À RÉALISER

PARTIE 1 — ANALYSE DE SÉCURITÉ DE L'APPLICATION 🔍

/4 points

Vous devez réaliser une analyse de sécurité de l'application fournie.

Identifiez **au minimum 5 problèmes ou vulnérabilités de sécurité**.

Les vulnérabilités peuvent concerner, par exemple :

- SQL Injection ;
- Cross-Site Scripting (XSS) ;
- Broken Access Control / IDOR ;
- authentification insuffisamment sécurisée ;
- exposition de données sensibles ;
- mots de passe ou secrets exposés ;
- mauvaise configuration de sécurité ;
- dépendances vulnérables ;
- validation insuffisante des entrées ;
- autres faiblesses pertinentes.

Pour chaque vulnérabilité, fournissez :

- une description claire ;
- le composant concerné ;
- la catégorie **CWE** correspondante ;

- le risque pour l'application.

Tableau attendu

ID	Vulnérabilité	Composant	CWE	Description
V1	SQL Injection	Authentication	CWE-89	...
V2	XSS	Search	CWE-79	...

PARTIE 2 — ANALYSE DES RISQUES ET PROTECTION DES DONNÉES

/4 points

Pour chaque vulnérabilité identifiée, analysez son impact sur la sécurité des données.

Vous devez utiliser les trois propriétés fondamentales :

Confidentialité

Une personne non autorisée peut-elle accéder aux données ?

Intégrité

Une personne non autorisée peut-elle modifier les données ?

Disponibilité

Une attaque peut-elle empêcher l'accès aux données ou au système ?

Tableau attendu

Vulnérabilité	Confidentialité	Intégrité	Disponibilité	Impact
SQL Injection	Oui	Oui	Possible	Critical
XSS	Oui	Possible	Non	High

Vous devez également :

- attribuer un niveau de criticité ;
- justifier la priorité de correction.

Vous pouvez utiliser :

- Critical ;

- High ;
- Medium ;
- Low.

PARTIE 3 — REMÉDIATION ET SÉCURISATION

/4 points

Sélectionnez **au minimum 3 vulnérabilités importantes** parmi celles identifiées.

Pour chacune :

1 Expliquez la cause

Pourquoi la vulnérabilité existe-t-elle ?

2 Proposez une correction

Quelle solution permet de réduire ou éliminer le risque ?

3 Justifiez votre choix

Pourquoi cette correction est-elle efficace ?

4 Vérifiez la correction

Montrez comment vous avez vérifié que le problème a été corrigé ou réduit.

Exemple de structure attendue

Vulnérabilité	Cause	Remédiation	Vérification
SQL Injection	Entrées non sécurisées	Requêtes paramétrées	Test + outil
XSS	Sortie non encodée	Output encoding	Test + scan

PARTIE 4 — AUTOMATISATION DES CONTRÔLES DE SÉCURITÉ

/4 points

Vous devez mettre en place ou proposer un pipeline Jenkins permettant d'automatiser des contrôles de sécurité.

Votre pipeline doit contenir au minimum les étapes suivantes :

1. Checkout
- ↓
2. Build / Preparation
- ↓
3. Security Analysis
- ↓
4. Additional Security Check
- ↓
5. Report Generation
- ↓
6. Notification

Vous devez intégrer **au minimum deux types de contrôles de sécurité** parmi :

SAST

Analyse statique du code source.

DAST

Analyse dynamique de l'application en fonctionnement.

SCA

Analyse des dépendances et composants logiciels.

Secret Detection

Détection de mots de passe, clés API ou secrets exposés.

Pour chaque outil utilisé, expliquez :

- Quel type d'analyse réalise-t-il ?
- Quelles vulnérabilités peut-il détecter ?
- Quelles sont ses limites ?
- À quel moment intervient-il dans le pipeline ?

PARTIE 5 — ANALYSE DES RÉSULTATS ET DÉCISION DE DÉPLOIEMENT

/2 points

Après l'exécution du pipeline, vous devez analyser les résultats.

Supposons que plusieurs vulnérabilités soient détectées.

Vous devez les classer selon leur priorité.

Tableau attendu

Problème	CWE	Sévérité	Action recommandée
SQL Injection	CWE-89	Critical	Bloquer le déploiement
XSS	CWE-79	High	Correction requise
Information Exposure	CWE-200	Medium	Correction planifiée

Question finale

Répondez à la question suivante :

L'application est-elle prête à être déployée en production ?

Choisissez une réponse :

- ☒ **Accept Deployment**
- ☐ **Accept with Conditions**
- ☐ **Reject Deployment**

Vous devez justifier votre décision sur la base des résultats obtenus.

PARTIE 6 — ANALYSE CRITIQUE 🧠

/2 points

Répondez individuellement à la question suivante :

Un outil de sécurité qui ne détecte aucune vulnérabilité peut-il garantir qu'une application est sécurisée ?

Votre réponse doit discuter notamment :

- les faux positifs ;
- les faux négatifs ;

- les limites des outils ;
- la couverture des règles ;
- l'importance de l'analyse humaine.

Longueur recommandée : 300 à 500 mots.

4. LIVRABLES

LIVRABLE 1 — Rapport de sécurité

Format :

- PDF ;
- **8 à 12 pages maximum**, hors annexes.

Le rapport doit contenir :

1. Introduction ;
 2. Méthodologie ;
 3. Vulnérabilités identifiées ;
 4. Classification CWE ;
 5. Analyse des impacts ;
 6. Remédiations ;
 7. Pipeline de sécurité ;
 8. Résultats ;
 9. Décision de déploiement ;
 10. Conclusion.
-

LIVRABLE 2 — Dépôt Git

Le dépôt doit contenir :

```
project/
|
├── README.md
├── Jenkinsfile
├── reports/
├── screenshots/
├── security-config/
└── remediation/
```

Le `README.md` doit expliquer :

- comment exécuter le projet ;
- comment lancer les analyses ;

- les outils utilisés.

LIVRABLE 3 — Démonstration

Une courte vidéo de :

5 à 10 minutes maximum

doit présenter :

1. l'application ;
2. les principaux problèmes identifiés ;
3. une ou plusieurs remédiations ;
4. le pipeline Jenkins ;
5. les résultats ;
6. la décision finale.

5. BARÈME DÉTAILLÉ

Critère	Points
Identification des vulnérabilités	4 pts
CWE + analyse CIA + risques	4 pts
Remédiation et vérification	4 pts
Pipeline Jenkins / automatisation	4 pts
Analyse et décision de déploiement	2 pts
Analyse critique	2 pts
TOTAL	20 pts